# Unidad 110: Seguridad en el sistema

- 110.1: Seguridad en la administración de tareas (3)
- 110.2: Instalando seguridad en el sistema (3)
- 110.3: Seguridad en los datos y encriptación (2)

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Privilegios Especiales**

Los privilegios especiales de ejecución **(bits SUID y SGID)** suelen ser causa de inseguridad en el sistema. En efecto, un usuario malintencionado, aprovechando la falta de atención o la ausencia de un compañero o un administrador que no está desconectado de su consola, puede modificar los permisos de ciertos comandos a su favor.

El ejemplo más habitual es el de reescribir un shell como un programa poco usado (por ejemplo sx) y darle los privilegios **SUID**. Al iniciar este comando, se puede convertir en root.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

## Privilegios Especiales

Añade/elimina permisos **SUID** a un binario de ejemplo (usuario):

# chmod u+s /home/user/ejecutable

**#** chmod u-s /bin/user/ejecutable

Añade/elimina permisos **GUID** a un binario de ejemplo (grupo):

# chmod g+s /home/user/ejecutable

# chmod g-s /home/user/ejecutable

*Obtener el permiso de listar todos los ficheros:*
# chmod u+s /bin/**cat**

*Quitar el permiso de ejecutar el comando ping:*
# chmod u-s /bin/**ping**

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Privilegios Especiales**

El comando siguiente permite buscar todos los ficheros que disponen de los bits SUID o SGID:

*# find / -type f \( -perm -4000 -o -perm -2000 \)*

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Política de Contraseñas**

Las contraseñas son la base de la autenticación de un usuario. Deben ser seguras.

Los usuarios deben elegir una buena contraseña, evitando la sencillez o más bien lo evidente: nombres de los hijos, de la esposa, de lugares, fecha de nacimiento y, en general, todo lo que importa y que es conocido del entorno profesional o personal.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Política de Contraseñas**

Deberían poder definirse cambios de contraseñas a menudo.
Para ello usamos el comando **chage**

*# chage -l fhf*

*Minimum: 7*

*Maximum: 40*

*Warning: 10*

*Inactive: 5*

*Last Change: abr 10, 2008*

*Password Expires: may 20, 2008*

*Password Inactive: may 25, 2008*

*Account Expires: ene 01, 2010*

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Política de Contraseñas**

Los **módulos PAM** influyen en la política de gestión de las contraseñas, obligando en algunos casos a elegir una más o menos compleja.

Una buena configuración de PAM puede ayudarnos a ser más o menos estrictos en temas de contraseñas.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**ulimit**

El comando ulimit permite actuar en el entorno del shell y de los procesos que controla. El parámetro -a (**ulimit -a**) muestra las opciones controladas por ulimit. Los parámetros más detacables podrían ser:

**max memory size**: el tamaño de memoria máximo que puede ocupar el usuario.

**open files**: el número máximo de descriptores de ficheros; por lo tanto, el número máximo de ficheros que se pueden

abrir.

**max user processes**: el número máximo de procesos que puede iniciar un usuario.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**ulimit**

- El administrador puede controlar los valores por defecto en el fichero: **/etc/security/limits.conf**

- Se pueden cambiar estos valores según ciertos límites impuestos por el administrador. Existen límites **soft** (suaves o bajos) que son los valores por defecto devueltos por **ulimit**, y límites **hard** (duros, altos), que no se pueden superar.

Para pasar el número máximo de ficheros abiertos a 2048:

**#ulimit -n 2048**

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Derechos sudo**

El comando **sudo** permite asignar el derecho a ejecutar comandos de administrador a uno o varios usuarios, en una o varias máquinas.

Para que un usuario pueda ejecutar un comando que, en principio, sólo puede ejecutar root, debe añadirse un derecho sudo a este usuario para este comando.

El fichero de configuración de sudo es **/etc/sudoers**. Es posible editarlo a mano o con el comando **visudo**. Este último

comando comprueba la sintaxis del fichero en el momento de guardar.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Derechos sudo**

La sintaxis queda algo tal que así:
*user machine = (user2) comando*

Dónde:

- **user**: el usuario (o alias) al cual se aplica la regla.
- **máquina**: la máquina (o el alias) en la cual se aplica la regla.
- **user2**: la cuenta con la cual el usuario ejecutará el comando.
- **comando**: el comando que se va a ejecutar.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**Derechos sudo : Ejemplo**

*fhf ALL = /sbin/fsck*

Estamos dando al usuario fhf permisos para ejecutar un fsck

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**/etc/sudoers**

El ejemplo anterior es deliberadamente limitado. Es posible:

- crear grupos de usuarios,
- crear grupos de máquinas,
- crear grupos de comandos,
- forzar o no el uso de una contraseña,
- forzar la ejecución de un comando bajo un usuario distinto de root.

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**netstat**

Permite obtener información y estatísticas de red sobre una máquina local. En particular se puede comprobar cuáles son los puertos a la escucha en su máquina, quién ha establecido una conexión y qué procesos locales (servicios) están a la escucha

**#netsat -putan**

# 110.1 : Seguridad en la Administración de tareas (Peso: 3)

**nmap**

Herramienta de exploración de red y de control de seguridad. Permite probar las conexiones de red de una máquina determinada y obtener mucha información.

**#nmap host**

En particular, analizando tramas, logra determinar el tipo y la versión del sistema operativo remoto.

**#nmap –A host**

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

**Conexiones**

Algunas cuentas no deben ser interactivas: se deben prohibir las conexiones desde una consola. Se pueden asignar estas cuentas a una aplicación, a un servicio, a una conexión FTP, etc., pero se debería rechazar la conexión: ¡no shell!

Dentro del archivo **/etc/shells** podremos encontrar las shells más habituales

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

**Conexiones - Shells**

El shell **/bin/false** no es realmente un shell. Prohíbe las conexiones interactivas.

Antes de pasar por un seudoshell de conexión, los módulos PAM permiten aplicar numerosas limitaciones. Entre ellas, el módulo **pam_nologin**, que le permite prohibir la conexión de los usuarios excepto root. Este módulo monitoriza si un usuario intenta conectarse al fichero **/etc/nologin**. Es útil para tareas de mantenimiento, ya que sólo root se puede conectar

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

**TCP wrappers**

Los **tcp_wrappers** permiten la comprobación de los accesos a un servicio de red determinado (service, xinetd, portmapper).

Cada programa que utiliza los **tcp_wrappers** se compila con la librería **libwrap** de manera estática (el comando ldd no permite ver la librería).

Para verificar una regla, el sistema lee primero **/etc/hosts.allow**, luego **/etc/hosts.deny**. La búsqueda se detiene a la primera correspondencia encontrada. Una línea en hosts.allow autoriza la conexión. Una línea en hosts.deny prohibe la conexión. Si no se deniega de manera explícita el acceso, se autoriza: la petición no corresponde a ningún criterio.

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

**TCP Ejemplo**

*# /etc/hosts.allow*

*vsftpd: 192.168.1.*

*in.telnetd, portmap: puesto1, puesto2*

*# /etc/hosts.deny*

*ALL: .baddominio.org except trusted.baddominio.org*

*vsftpd,in.telnetd,portmap: ALL*

*dovecot : 192.168.0. EXCEPT 192.168.1.5*

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

**Xinetd e initd**

Son servicios que usan gran parte de los sistemas Unix dedicado a administrar la conectividad basada en Internet. **xinetd** es una extensión más segura del servicio de Internet **inetd**.

**xinetd** contiene mecanismos de control de acceso como Wrappers TCP, Listas de Control de Acceso, y la posibilidad de habilitar los Servicios_de_red basándose en el tiempo. Puede limitar la cantidad de servicios que se ejecutan, y contiene un sistema de protección contra escaneos de puertos.

# 110.2 : Instalando seguridad en el sistema(Peso: 3)

## Xinetd e initd : Ejemplo /etc/xinetd.d/telnet

```
service telnet
{
  disable          = no
  flags            = REUSE       #Atributos para la conexion
  socket_type      = stream      #TCP / dgram = UDP
  wait             = no          # = multi-threaded
  user             = root
  server           = /usr/sbin/in.telnetd
  access_times     = 7:00-12:30 13:30-21:00
  bind             = 192.168.1.39       #Interfaz por donde se sirve el servicio
  only_from        = 192.168.1.0/24     #Clientes que tienen permitido el acceso
}
```

# 110.3 : Seguridad de los datos y encriptación (3)

**SSH**

Linux soporta el acceso remoto a través de varios servidores diferentes, incluyendo Telnet, VNC, e incluso X. Desafortunadamente, la mayoría de estos métodos sufren de un inconveniente importante: **la transferencia de todos los datos a través de la red es no cifrada**. Este hecho significa que cualquiera que pueda monitorear el tráfico de red puede arrebatar fácilmente datos sensibles, a menudo incluyendo las contraseñas. Esta limitación pone una seria disminución en la utilidad de estos inicio de sesión remoto herramientas, después de todo, si se utiliza un protocolo de acceso remoto significa que regalaremos datos sensibles o poner en peligro todo el equipo, no es un protocolo muy útil

# 110.3 : Seguridad de los datos y encriptación (3)

**OpenSSH**

La parte de servicio está basado en el fichero de configuración **/etc/ssh/sshd_config**. La configuración se determina por los campos:
*Opción valor*

Las opciones más comunes y que son más facilmente modificables son las siguientes:

**Protocol:** Los valores posibles son 1 y 2. Nivel Potocol 1 se ha visto comprometida, la configuración más segura es configurar el Protocolo 2. Esto limita la capacidad del servidor para comunicarse con los clientes más antiguos, sin embargo.

# 110.3 : Seguridad de los datos y encriptación (3)

## OpenSSH

**Port:** Numero de puerto en el cual se levanta el servicio. Por defecto es el puerto "22"

**PermitRootLogin:** De forma predeterminada, esta opción se establece en "yes“, lo que permite a OpenSSH para aceptar conexiones directas por parte de root.

**X11Forwarding:** Si se desea permitir que los usuarios remotos para ejecutar programas X a través de SSH, debe establecer esta opción a "yes“

Siempre que modifiquemos  las opciones del fichero de configuración es necesario reiniciar el servicio:

**#/etc/init.d/sshd restart**

# 110.3 : Seguridad de los datos y encriptación (3)

**ssh -client**

A parte del servicio OpenSSH, también tenemos el cliente para conectarnos.

***$ssh  jumpserver.fhf.es –l fhf***

Nos conectamos al servidor jumpserver.fhf.es con el usuario fhf

**$ssh fhf@*jumpserver.fhf.es***

# 110.3 : Seguridad de los datos y encriptación (3)

**ssh-keygen**

Nos permite generar una **key**, haciendo posible una conexión automática sin necesidad de introducir un contraseña:

***$ssh-keygen –t rsa***

Dicho comando generan las claves dentro del directorio **$HOME/.ssh** del usuario donde se ejecuto.

Debemos copiar la clave pública ( contenido de **id_rsa.pub**) dentro del fichero **$HOME/.ssh/authorized_keys** de la maquina remota.

Nos conectamos al servidor sin necesidad de password:

**$ssh** fhf@*jumpserver.fhf.es*

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG**

**GPG** (*Gnu Privacy Guard*) es un clon libre de **PGP** (*Pretty Good Privacy*). Implementa el algoritmo de cifrado RSA. PGP es objeto de una norma que GPG respeta. Esto significa que las dos implementaciones son compatibles: las llaves generadas por el uno o el otro se pueden intercambiar.

El objetivo de GPG es cifrar una comunicación gracias a un cifrado por claves asimétricas. Una clave permite firmar el texto, otra clave sirve para encriptar el texto.

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG**

El cifrado por claves asimétricas utiliza dos claves, una pública y otra privada:

- **clave pública**: difundida públicamente, permite al destinatario descifrar el mensaje que usted ha firmado (con la clave privada).
- **clave privada:** le permite firmar un mensaje. La persona que lo recibe comprueba su firma con la ayuda de la clave pública que usted le ha proporcionado, demonstrando así que usted es realmente el autor del mensaje.

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG – Generar claves**

*gpg --gen-key*

GPG empieza con crear, si no existen ya, el directorio raíz de GPG propio de cada usuario y los ficheros que contendrán los elementos gestionados por gpg.

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

```
seb@slyserver:~> gpg --gen-key
gpg (GnuPG) 2.0.9; Copyright (C) 2008 Free Software Foundation, Inc.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
gpg: directorio '/home/seb/.gnupg' creado
gpg: nuevo fichero de configuración '/home/seb/.gnupg/gpg.conf' creado
gpg: ADVERTENCIA: las opciones de '/home/seb/.gnupg/gpg.conf' aún no están
activas esta vez
gpg: la clave '/home/seb/.gnupg/secring.gpg' ha sido creada
gpg: la clave '/home/seb/.gnupg/pubring.gpg' ha sido creada
```

Luego seleccionamos el tipo de clave deseada:

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Seleccione el tipo de clave deseado:
(1) DSA y Elgamal (por defecto)
(2) DSA (firma sola)
(5) RSA (firma sola)
¿Su eleccin? 1

Luego debe elegir el tamaño, en bits, de la clave que hay que generar. Cuánto más larga es la clave, más complejo es el cifrado. Se puede elegir una clave de 1024 bits por ejemplo:

El par de claves DSA dará 1024 bits.
las claves ELG pueden tener entre 1024 y 4096 bits de longitud.
¿Qué tamaño de clave desea? (2048) 1024
El tamaño pedido es 1024 bits

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Seleccione el tipo de clave deseado:
(1) DSA y Elgamal (por defecto)
(2) DSA (firma sola)
(5) RSA (firma sola)
¿Su eleccin? 1

Luego debe elegir el tamaño, en bits, de la clave que hay que generar. Cuánto más larga es la clave, más complejo es el cifrado. Se puede elegir una clave de 1024 bits por ejemplo:

El par de claves DSA dará 1024 bits.
las claves ELG pueden tener entre 1024 y 4096 bits de longitud.
¿Qué tamaño de clave desea? (2048) 1024
El tamaño pedido es 1024 bits

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Posteriormente hay que indicar la duración de las claves. 0 para una duración infinita:

Especifique cuánto tiempo debería ser válida esta clave.
0 = la clave no expira
<n> = la clave expira en n días
<n>w = la clave expira en n semanas
<n>m = la clave expira en n meses
<n>y = la clave expira en n años
¿La clave es válida para? (0)
La clave no expira.
¿Es correcto? (s/N) s

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Luego habrá que añadir una serie de datos como nombre, email,etc:

Necesita un nombre de usuario para identificar su clave,
el programa lo construye a partir del nombre real, de un comentario y
de una dirección de email, de la manera siguiente:
«Heinrich Heine (Der Dichter) <heinrichh@duesseldorf.de>»
Nombre real: Sébastien ROHAUT
Dirección de e-mail: sebastien.rohaut@dominio.es
Comentario: slyce
Usted utiliza el juego de caracteres ’utf-8’.
Ha seleccionado este nombre de usuario:
"Sébastien ROHAUT (slyce) <sebastien.rohaut@dominio.es>"
Cambiar el (N)ombre, el (C)omentario, el (E)-mail o (O)K/(S)alir ? O

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Luego habrá que añadir una serie de datos como nombre, email,etc:

Necesita un nombre de usuario para identificar su clave,
el programa lo construye a partir del nombre real, de un comentario y
de una dirección de email, de la manera siguiente:
«Heinrich Heine (Der Dichter) <heinrichh@duesseldorf.de>»
Nombre real: Sébastien ROHAUT
Dirección de e-mail: sebastien.rohaut@dominio.es
Comentario: slyce
Usted utiliza el juego de caracteres ’utf-8’.
Ha seleccionado este nombre de usuario:
"Sébastien ROHAUT (slyce) <sebastien.rohaut@dominio.es>"
Cambiar el (N)ombre, el (C)omentario, el (E)-mail o (O)K/(S)alir ? O

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG – Generar claves**

La **passphrase** se pedirá esta frase a cada envío o recepción de mensaje privado encriptado. También asegura, al menos mientras no la encuentren, una cierta seguridad de la clave privada, incluso si la roban, ya que esta clave no se puede utilizar sin esta **passphrase**

Necesita una frase de contraseña para proteger su clave secreta.

Inserte la frase de contraseña:

Repita la frase de contraseña:

# 110.3 : Seguridad de los datos y encriptación (3)

## GPG – Generar claves

Se debe generar un gran número de bytes aleatorios. Tendría que
hacer otra cosa (teclear, mover el ratón, utilizar discos) durante la generación de los primeros
números. Eso da al generador de nombres aleatorios más oportunidad de tener
bastante entropía.
gpg: clave 13E021A8 marcada como si tuviera una confianza última.
se ha creado y firmado las claves pública y secreta.
gpg: comprobar la base de confianza
gpg: 3 marginale(s) necesarias, 1 completa(s) necesarias, modelo
de confianza PGP
gpg: profundidad: 0 válida: 1 firmado: 0
confianza: 0-. 0g. 0n. 0m. 0f. 1u
pub 1024D/13E021A8 2009-05-04
Huella de la clave = 6115 DE46 2678 40AB 0AB2 B8B9 1F12 D427 13E0 21A8
uid Sébastien ROHAUT (Slyce) <sebastien.rohaut@dominio.es>
sub 1024g/BA311C5C 2009-05-04

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG – Generar claves**

Las últimas cuatro líneas resumen toda la información relativa al trabajo efectuado por GPG:

- **pub**: da la longitud de la clave (1024 bits), de número 13E021A8, generada el 04/05/2009.
- **huella**: es el «fingerprint» que permite determinar la validez de la clave pública, un poco como la suma md5 de cualquier fichero. Es casi imposible (pero no del todo), que claves de gran tamaño tengan una huella idéntica.
- **uid**: información nominativa (nombre, comentario o alias/seudo, dirección email).
- **sub**: es el tamaño (1024 bits), el número y la fecha de generación de la clave privada

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG – Revocar claves**

Es posible que queramos cambiar nuestra clave por temas de seguridad, para ello, podemos revocarla.

gpg --gen-revoke *alias*

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG**

gpg --list-key: lista las claves generadas por GPG
gpg --list-sigs: lista de la firmas con sus claves
gpg --export  : exportamos la clave pública
gpg --import : importar la clave. Segundo parámetro para importar una clave existente en el servidor. Si no, la añadimos por consola
gpg --send-keys: exportar su clave pública hacia un servidor de claves GPG

# 110.3 : Seguridad de los datos y encriptación (3)

**GPG - encriptación**

Exportar la clave pública:
Gpg –output [archivo destino] –export [ID clave pública]

Para cifrar los datos, usa gpg con las siguientes opciones:
gpg --out encrypted-file --recipient uid --armor --encrypt original-file

Importar una clave pública:
Gpg –import XXX.gpg